

# A Game-Theoretic Decision-Making Framework for Engineering Self-Protecting Software Systems

Mahsa Emami-Taba

Software Technologies Applied Research (STAR) Group

University of Waterloo, Canada

msemamit@uwaterloo.ca

**Abstract**—Targeted and destructive nature of strategies used by attackers to break down the system require mitigation approaches with dynamic awareness. Making a right decision, when facing today's sophisticated and dynamic attacks, is one of the most challenging aspects of engineering self-protecting software systems. Inspired by game theory, in this research work, we model the interactions between the attacker and the software system as a two-player game. Using game-theoretic techniques, the self-protecting software systems is able to: (i) fuse the strategies of attackers into the decision-making model, and (ii) refine the strategies in dynamic attack scenarios by utilizing what has learned from the system's and adversary's interactions. This research introduces a novel decision-making framework with three phases: (i) *modeling quality goals* aiming at incorporating them into the decision model, (ii) *designing game-theoretic techniques* in order to build the decision model, and (iii) *realizing the decision-making engine* in the adaptation manager. Modeling quality goals provides the adaptation manager with the knowledge-base required in making a systematic adaptation decision. The framework aims at exhibiting a plug-and-play capability to adapt game-theoretic techniques that suite security goals and requirements of the software.

**Keywords**—Self-Protecting Software, Decision Making, Game Theory, Software Quality Goals.

## I. INTRODUCTION

Today's life style is largely dependent on software systems. Securing these systems and their information are a critical concern from personal to governmental scale standpoint. However, the increasing complexity and interconnectivity of software systems makes it difficult to achieve a desired level of security. In these systems, a great challenge for administrators is to select timely and appropriate countermeasures in response to attacks. However, the proactive and dynamic nature of security attacks demands fast reacting adaptive systems that are able to detect and mitigate threats on the fly while ensuring system's security goals of confidentiality, integrity, and availability. *Self-Protecting software* (SPS) is a response to these demands. The main objective of SPS systems is to satisfy security goals and requirements. An important issue in these systems is how to make adaptation decision as a response to a detected threat or to deviations from security goals and requirements. The aforementioned issue has set the main goal of this PhD research thesis. We aim at providing a novel systematic approach for decision making in self-protecting software systems.

## II. STATE-OF-THE-ART RESEARCH

A number of projects in the area of SPS systems is selected and described in this section. These projects are selected on the basis of their impacts and novelties in this area. The surveyed research papers do not generalize all SPS systems. However, they helped us to highlight common patterns and trends in this field of study.

We summarize observations obtained from the study of technical tools and techniques for SPS systems in Table I. The comparison of different techniques in SPS is based on three dimensions: *goal/requirement*, *architecture-layer*, and *decision making*. We must point out that this classification has no intention of being exhaustive. We made the choice to focus on these three main aspects that we identified as key aspects in engineering SPS systems. The result of our comparison yields the following insights.

- **Goal/Requirement:** All the studied SPS tools and techniques focus on anticipation and prevention of adaptation goals [1]...[13], and less or no effort is dedicated to limiting the spread of attack at the time of attack, minimizing the consequences of the attack, or recovering to a trusted state after the attack.
- **Architecture-Layer:** Architecture-based approaches to self-adaptive systems introduced in [14] and since then has been studied thoroughly in runtime software adaptation. Most research in SPS systems is focused on one specific architecture layer (e.g., [1] and [10]). This fact limits the knowledge of the system and/or its environment and consequently restricts the mitigating actions through adaptation mechanisms. Information at the network layer is employed in adaptive intrusion detection systems and intrusion prevention systems. Host-layer SPS systems provide antivirus/malware detection. Application-layer SPS systems mostly address vulnerabilities that are related to programming language level such as memory buffers and pointers.
- **Decision Making:** One of the key challenges of feedback control loops in adaptive systems is designing the decision-making technique [15]. Classical techniques (e.g., heuristic) are the most used decision-making technique in SPS. Machine learning is employed in a few approaches. However, it is notable that the application of game theory in SPS systems is not yet investigated. Machine learning techniques, such as anomaly detection, are good candidates to address unknown

TABLE I  
COMPARING SPS RESEARCH PROJECTS IN THREE MAIN DIMENSIONS

| Article            | Dimension | Goal/Requirement |           |              | Architecture-Layer |            |                  |         | Decision Making |           |                  |
|--------------------|-----------|------------------|-----------|--------------|--------------------|------------|------------------|---------|-----------------|-----------|------------------|
|                    |           | Confidentiality  | Integrity | Availability | Application        | Middleware | Operating System | Network | Abstract        | Classical | Machine Learning |
| Lorenzoli 2007 [1] |           |                  | ×         |              | ×                  |            |                  |         |                 | ×         |                  |
| Al-Nashif 2008 [2] |           | ×                | ×         | ×            |                    |            |                  | ×       |                 | ×         | ×                |
| Yu 2008 [3]        |           | ×                | ×         |              |                    |            |                  | ×       |                 | ×         |                  |
| He 2008 [4]        |           | ×                | ×         | ×            |                    |            | ×                | ×       |                 | ×         |                  |
| Okhravi 2010 [5]   |           |                  |           | ×            |                    |            | ×                | ×       |                 | ×         |                  |
| Savola 2010 [6]    |           | ×                | ×         | ×            |                    |            | ×                | ×       |                 |           |                  |
| Jung 2010 [7]      |           | ×                | ×         |              |                    |            |                  | ×       |                 | ×         |                  |
| Bouchenak 2011 [8] |           |                  |           | ×            |                    | ×          |                  |         |                 | ×         |                  |
| Blount 2011 [9]    |           |                  | ×         |              | ×                  |            |                  |         |                 |           | ×                |
| Pasquale 2012 [10] |           | ×                | ×         | ×            | ×                  |            |                  |         |                 | ×         |                  |
| Salehie 2012 [11]  |           | ×                | ×         | ×            | ×                  |            |                  |         |                 | ×         |                  |
| Schmerl 2014 [12]  |           |                  |           | ×            |                    |            |                  |         | ×               |           |                  |
| Bailey 2014 [13]   |           | ×                | ×         |              | ×                  |            |                  |         | ×               | ×         |                  |

attacks. These techniques are widely used in intrusion detection systems at the network level. Similarly game theory is increasingly applied to network security. The application of game theory in application-level security has not gained the deserved attention. In Application-layer attacks are more sophisticated than network attacks as attackers can dynamically change their strategies to stay hidden from the Intrusion Detection System (IDS).

The next section defines our research problem based on the research gaps discussed here.

### III. RESEARCH METHODOLOGY

In order to address the limitations of adaptive security methods, we consider the decision-making process in SPS as a two-player game, in which adaptation manager and the attacker are the players that compete with each other over system resources. In this game, the adaptation manager tracks the attackers strategy and reacts according to the changes in their strategy. Rationality of players is an important underlying assumption of the security games which is also considered in our methodology.

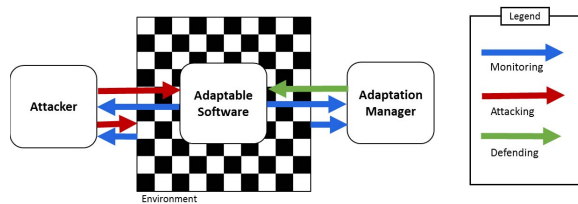


Fig. 1. Two-Player Game in Self-Protecting Software System

A high-level context model of our perspective is shown in Fig. 1. The blue arrows represent that both the adaptation manager and the attacker are able to monitor the state of software and its environment. However, in most cases, adaptation manager has a white-box view of the system,

which may not be the case with the attacker. The red arrows represent attackers actions, these can be either in the form of actions that affect the adaptable software directly with the intention of breaking the system down, or the ones that can affect the operating environment and its state. The green arrow represents mitigation actions selected by the adaptation manager and to be executed by or on the adaptable software.

**Problem Definition:** *How to realize the decision-making process in SPS systems with the aid of game-theoretic techniques?*

To employ a game-theory technique, we first need to model the payoff of the players (SPS and the attacker). The aim is to incorporate the knowledge gathered from their goals. Modeling the knowledge of the players facilitates interpretation of the relation among various sources of data and the impact of actions that can be taken by each player.

#### A. The Proposed Framework

To tackle the specified problem, a step-wise research approach is required. Fig. 2 depicts the phases of our proposed framework.

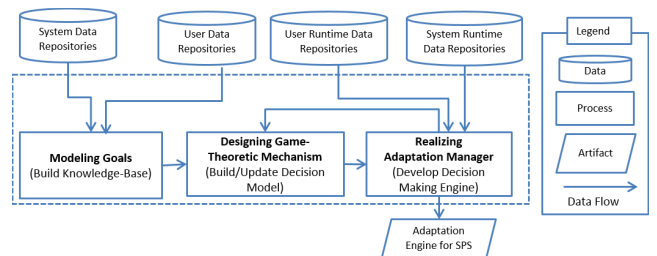


Fig. 2. Game-Theoretic Decision-Making Framework

• **Modeling Goals.** In SPS systems, the knowledge incorporated in decision making is not limited to the software itself and its running environment. The users of the system are the

potential attackers to the system. Hence, the knowledge that captures the behavior (and ultimately trustworthiness) of users can enhance the quality of decision making. We plan to model the knowledge required by the adaptation manager by exploiting goal-oriented and agent-oriented modeling techniques. These techniques facilitate trade-off analysis among agents' goals and provide a suitable base for dealing with security. Agent-oriented modeling captures the required knowledge not only from the adaptable system's perspective but also from malicious user's perspective. The analysis of these two agents' goals and actions will further facilitate the analysis of security decisions for the decision-making engine in a SPS system.

• **Designing Game-Theoretic Mechanism.** The second phase of the research is designing the planning process of SPS with the aid of game theory. Game-theory techniques are a natural fit to quantitatively analyze multi-players actions and utilities. They are distinguishable from other techniques in considering the strategy of the opponent when choosing the next action. Hence, game theory aids in trade-off analysis of security countermeasures and possible attacks. Moreover, dynamically adaptive systems must be able to update the runtime model depending on environmental conditions and switch between runtime configurations without disrupting the running system [16]. Hence, the model built in this phase is required to get updated during runtime.

• **Realizing Adaptation Manager.** The third phase of the research is the development process in order to realize the first two phases. The first step of this phase covers collecting the required information to build the goal-oriented model and map the model to a game-theoretic technique. Next step is to develop the decision-making engine. The last step in this phase includes evaluating and testing the planning process by appropriate test cases.

In the proposed framework, the research objective is to provide decision making at runtime to adapt the system in supporting security goals while incorporating likelihood of an attack.

#### B. Expected Research Contributions

The objective of the proposed research to the problem of decision making in SPS systems is engineering a framework that helps to realize the planning process in SPS which considers goals and strategies of the system and malicious users in its decision-making engine. The main contributions of the envisioned framework are:

- *Incorporating both security and non-security goals:* It should allow reasoning about security goals considering other quality goals such as performance, cost, or usability depending on the business goals of the system and hence capturing trade-offs among security and non-security goals
- *Protecting against various attacks:* The decision-making methodology should not be merely specific to a certain type of attack. It should address general decision-making design and development principles for protecting against various types of attacks.

- *Using goal-oriented models:* The modeled framework should not only consider the goals regarding the adaptable system, but also incorporate the malicious goals of attackers as basis for reasoning in choosing a countermeasure
- *Addressing dynamic attack strategies:* It should not only mitigate the attacks that do not change their strategy, but also prevent complex attacks that change their strategy to stay hidden from the intrusion detection system.
- *Designing a systematic evaluation approach:* The goal-oriented model and decision-making mechanism need to be evaluated by various case studies to reason about the effectiveness of the selected strategy during runtime.

It is worth mentioning that the main goal of this research is realizing the *Planning* process of the MAPE-K model and other three processes in the MAPE-K (i.e., *Monitoring*, *Analyzing*, and *Executing*) are not the focus of this research.

#### IV. THE RESEARCH PROGRESS

The research progress can be enumerated as follows:

- The idea of a holistic and game-theoretic decision-making for adaptive security was discussed in [20]. This article was later selected to be published in the Cyber Security E-Book: *Best of TIM Review, Kindle Edition*.
- The modeling aspect of self-protecting software systems in our research methodology was presented in Canadian Consortium for Software Engineering Research (CSER) in November 2014. The poster received *Best Poster* award (3<sup>rd</sup> place).
- A study in mitigating application-layer SIP flood attack in VoIP telephony systems is conducted by applying Markov game technique and the obtained results were presented in IBM 24th Annual International Conference on Computer Science and Software Engineering. The presented poster won the *IBM Best Exhibit* award.
- Another article discussed the idea of adaptation based on strategy of the attacker and mitigation of attacks considering preferences in quality goals. This position paper was published in Emerging Technologies Track (ETT) in IBM 24th Annual International Conference on Computer Science and Software Engineering [17].
- Our paper published in [18] elaborates on our study of strategy-aware mitigation using Markov games for dynamic application-layer attacks. In this paper, a simulated case study using MATLAB Simulink was performed to gauge our game-theoretical approach in SPS systems.
- Our latest publication focuses on addressing uncertainty about adversary types in SPS systems using Bayesian game technique [19]. This paper won the *Best Student Paper* award in IBM 26th Annual International Conference on Computer Science and Software Engineering.

In order to illustrate the plug-and-play capability of our proposed framework in Section III, a summary of the relation of each proposed approach in the published papers to the original framework is provided in Table II.

#### V. FUTURE RESEARCH PLAN

The plan for the last year of my PhD is to continue studying other game theoretic techniques (e.g., Stackelberg games) that

TABLE II  
PUBLICATION LINKED WITH RESEARCH METHODOLOGY

| Phase<br>Publication                                                                           | Modeling Goals                                                | Designing Game-Theoretic Mechanism                             | Realizing Adaptation Manager                                       |
|------------------------------------------------------------------------------------------------|---------------------------------------------------------------|----------------------------------------------------------------|--------------------------------------------------------------------|
| <i>Mitigating Dynamic Attacks Using Multi-Agent Game-Theoretic Techniques</i> [17]             | Soft-goal Interdependency Graph (SIG)                         | Multi-Agent Game-Theoretic Technique (Strategy-aware approach) | Case study example considering the interdependencies of strategies |
| <i>Strategy-Aware Mitigation Using Markov Games for Dynamic Application-Layer Attacks</i> [18] | Goal-driven models such as Goal-Action-Attribute Model (GAAM) | Markov Game Technique (Learning-based approach)                | MATLAB Simulink - simulation of a web application                  |
| <i>A Bayesian Game Decision-Making Model for Uncertain Adversary Types</i> [19]                | Using NFR to model cost & benefits of attacks/countermeasures | Bayesian Game Technique (Considers uncertainty)                | VoIP java-based telephony system                                   |

can be applied to adaptive security in SPS systems. Moreover, I plan to evaluate and publish the proposed Markov Game Decision-Making Engine (MGDME) which combines game theory and reinforcement learning techniques. The proposed decision-making approach learns to select the proper countermeasure as the system evolves.

In addition, I plan to evaluate and publish the proposed Strategy-Aware Self-Protection (SASP) approach which is the extension of our position paper [17]. SASP employs the stochastic game technique and incorporates interdependencies among attack and defense strategies using quality goals of the software system in order to mitigate diverse attack strategies. Currently I work on providing a formal analysis of SASP with the aid of model checking of Stochastic Multi-player Games (SMGs) [21] using PRISM-games [22].

#### REFERENCES

- [1] D. Lorenzoli, L. Mariani, and M. Pezze, "Towards self-protecting enterprise applications," in *Proceedings of International Symposium on Software Reliability*, 2007, pp. 39–48.
- [2] Y. Al-Nashif, A. A. Kumar, S. Hariri, G. Qu, Y. Luo, and F. Szidarovsky, "Multi-level intrusion detection system (ML-IDS)," in *Proceedings of International Conference on Autonomic Computing*, 2008, pp. 131–140.
- [3] Z. Yu, J. J. Tsai, and T. Weigert, "An adaptive automatically tuning intrusion detection system," *ACM Transactions on Autonomous and Adaptive Systems*, vol. 3, no. 3, pp. 10:1–10:25, 2008.
- [4] R. He and M. Lacoste, "Applying component-based design to self-protection of ubiquitous systems," in *Proceedings of Workshop on Software Engineering for Pervasive Services*, 2008, pp. 9–14.
- [5] H. Okhravi, E. I. Robinson, S. Yannalfo, P. W. Michaleas, J. Haines, and A. Comella, "TALENT: Dynamic platform heterogeneity for cyber survivability of mission critical applications," in *Proceedings of Secure and Resilient Cyber Architecture Conference*, 2010.
- [6] R. M. Savola and P. Heinonen, "Security-measurability-enhancing mechanisms for a distributed adaptive security monitoring system," in *Proceedings of International Conference on Emerging Security Information Systems and Technologies*, 2010, pp. 25–34.
- [7] Y. Jung and M. Chung, "Adaptive security management model in the cloud computing environment," in *Proceedings of International Conference on Advanced Communication Technology*, 2010, pp. 1664–1669.
- [8] S. Bouchenak, F. Boyer, B. Claudel, N. De Palma, O. Gruber, and S. Sicard, "From autonomic to self-self behaviors: The jade experience," *ACM Transactions on Autonomous and Adaptive Systems*, vol. 6, no. 4, pp. 28:1–28:22, 2011.
- [9] J. J. Blount, D. R. Tauritz, and S. A. Mulder, "Adaptive rule-based malware detection employing learning classifier systems: a proof of concept," in *Proceedings of Annual Computer Software and Applications Conference Workshops*, 2011, pp. 110–115.
- [10] L. Pasquale, C. Menghi, M. Salehie, L. Cavallaro, I. Omoronyia, and B. Nuseibeh, "SecuriTAS: A tool for engineering adaptive security," in *Proceedings of International Symposium on the Foundations of Software Engineering*, 2012, pp. 19:1–19:4.
- [11] M. Salehie, L. Pasquale, I. Omoronyia, R. Ali, and B. Nuseibeh, "Requirements-driven adaptive security: Protecting variable assets at runtime," in *Proceedings of International Requirements Engineering Conference*, 2012, pp. 111–120.
- [12] B. Schmerl, J. Cámara, J. Gennari, D. Garlan, P. Casanova, G. A. Moreno, T. J. Glazier, and J. M. Barnes, "Architecture-based self-protection: Composing and reasoning about denial-of-service mitigations," in *Proceedings of Symposium and Bootcamp on the Science of Security*, 2014, pp. 2:1–2:12.
- [13] C. Bailey, L. Montrieux, R. de Lemos, Y. Yu, and M. Wermelinger, "Run-time generation, transformation, and verification of access control models for self-protection," in *Proceedings of International Symposium on Software Engineering for Adaptive and Self-Managing Systems*, 2014, pp. 135–144.
- [14] P. Oreizy, N. Medvidovic, and R. N. Taylor, "Architecture-based runtime software evolution," in *Proceedings of the international conference on Software engineering*, 1998, pp. 177–186.
- [15] R. Lemos et al., "Software engineering for self-adaptive systems: A second research roadmap," in *Software Engineering for Self-Adaptive Systems II, Lecture Notes in Computer Science*. Springer, 2013, vol. 7475, pp. 1–32.
- [16] A. Mosincat, W. Binder, and M. Jazayeri, "Runtime adaptability through automated model evolution," in *Proceedings of International Enterprise Distributed Object Computing Conference*, 2010, pp. 217–226.
- [17] M. Emami-Tabataba, M. Amoui, and L. Tahvildari, "Mitigating dynamic attacks using multi-agent game-theoretic techniques," in *Proceedings of IBM International Conference on Computer Science and Software Engineering*, 2014, pp. 375–378.
- [18] M. Emami-Tabataba, M. Amoui, and L. Tahvildari, "Strategy-aware mitigation using Markov games for dynamic application-layer attacks," in *Proceedings of International Symposium on High-Assurance Systems Engineering*, 2015, pp. 134–141.
- [19] M. Emami-Tabataba and L. Tahvildari, "A Bayesian game decision-making model for uncertain adversary types," in *Proceedings of IBM International Conference on Computer Science and Software Engineering*, 2016, p. 10 pages.
- [20] M. Emami-Tabataba, M. Amoui, and L. Tahvildari, "On the road to holistic decision making in adaptive security," *Technology Innovation Management Review*, vol. 3, no. 8, pp. 59–64, 2013.
- [21] T. Chen, V. Forejt, M. Kwiatkowska, D. Parker, and A. Simaitis, "Automatic verification of competitive stochastic systems," *Formal Methods in System Design*, vol. 43, no. 1, pp. 61–92, 2013.
- [22] T. Chen, V. Forejt, M. Kwiatkowska, D. Parker, and A. Simaitis, "Prism-games: A model checker for stochastic multi-player games," in *Tools and Algorithms for the Construction and Analysis of Systems*, ser. Lecture Notes in Computer Science, 2013, vol. 7795, pp. 185–191.